MacZine
THE MACTECH SOLUTIONS NEWSLETTER
ISSUE Nº 074 · NOVEMBER 2026 · MACTECHSOLUTIONSLLC.COM/MACZINE

CONTROL EXPLAINER · MEDIA PROTECTION

Backup CUI Under 3.8.9: The Restore Is the Evidence

NIST 800-171 control 3.8.9 is worth one SPRS point, but proving it pulls in FIPS crypto, cloud providers and offsite copies. A restore test proves it.

BY **MAXINE** READING TIME · 6 MIN NIST-800-171 · BACKUP · CUI · FIPS-140 · CMMC-LEVEL-2

The cheapest line on the CMMC Level 2 scoresheet guards the most complete copy of controlled unclassified information most small contractors own. Requirement 3.8.9 of NIST SP 800-171 Rev. 2 reads, in full, "Protect the confidentiality of backup CUI at storage locations." The DoD Assessment Methodology weighs it at 1 point, and NIST SP 800-171A gives it exactly one objective: determine whether the confidentiality of backup CUI is protected at storage locations. Programs see a single point and a single sentence and file it next to the visitor log.

That reading has the weight right and the work wrong. The backup is the enclave's file share, its drawings and its contract correspondence, copied on a schedule to somewhere else and kept for months. The enclave got a boundary diagram, a hardened baseline and multifactor login. The backup target usually got a service account and a retention setting from whoever installed the software. And the proof that 3.8.9 is met does not live in a policy. It lives in what happens when somebody tries to get the data back.

800-171A tells an assessor to reach that proof three ways: examine, interview and test. Taken in that order, they describe the whole job.

FIELD COPY
ISSUE Nº 074
NIST 800 171

1

SPRS POINT CARRIED BY 3.8.9 IN THE DOD ASSESSMENT METHODOLOGY, AGAINST A SINGLE 800-171A OBJECTIVE

5 or 3

POINTS LOST ON 3.13.11 WHEN BACKUP ENCRYPTION IS ABSENT, OR PRESENT BUT NOT FIPS-VALIDATED

180 days

THE ONE POA&M WINDOW 32 CFR 170.21 ALLOWS AN ELIGIBLE 1-POINT GAP SUCH AS 3.8.9

What the examine list makes you produce

The examine list for 3.8.9 names procedures addressing system backup, the security plan, backup storage locations, and backup logs or records. Read the third item slowly. It is plural, and so is the requirement's last phrase. Every place a backup lands is a place CUI is stored, and an assessor working that list will open the backup job, read its destinations off the configuration, and ask how each one protects confidentiality.

For a ten-person shop the destinations are rarely exotic. There is a NAS in the server closet, a cloud tier the backup product offered at setup, perhaps a USB drive rotated offsite on Fridays, and occasionally a replication target nobody remembers enabling. Each one drags a different rule behind it, and this is where the single point stops measuring the exposure.

Most programs protect backup confidentiality with encryption, which is sensible. The moment encryption is the mechanism, requirement 3.13.11 applies: cryptography protecting CUI confidentiality must be FIPS-validated, and the methodology subtracts 5 points if it is absent and 3 if it is present but unvalidated. The backup product's encryption checkbox is a cryptographic module like any other, and MacZine has argued that FIPS validation is the control that fails quietly precisely on paths like this one. Requirement 3.13.16, protecting CUI at rest, adds a point of its own.

The cloud tier is a provider decision before it is a storage setting. A service that stores CUI on the contractor's behalf falls under DFARS 252.204-7012(b)(2)(ii)(D), which requires security equivalent to the FedRAMP Moderate baseline along with the clause's incident reporting and forensic cooperation terms. That is the same external service provider decision a program makes for its email, and the backup vendor is often the one provider nobody put through it. The

◆ THE COPY THAT GOES HOME ON FRIDAY

Requirement 3.8.6 asks for cryptographic protection of CUI on digital media during transport unless alternative physical safeguards protect it. A drive carried to an offsite safe each week is media in transport, so it is either encrypted or covered by a documented physical safeguard for the trip.

Friday drive engages 3.8.6, covered in the margin. The closet NAS sits inside whatever physical protection the program built, or outside it.

The examine list, done honestly, produces a table: each destination, its encryption and certificate number, its provider and FedRAMP status where it is a cloud service, and its line on the boundary diagram in the security plan. A destination that will not fit on that diagram is the finding.

◆ WHERE AVAILABILITY WENT

NIST SP 800-171 Rev. 2 has no contingency planning family. Whether a backup can actually be restored is a business question the requirement set leaves to you, which is exactly why the restore is worth running anyway.

The interview is about the key

The interview list names personnel with backup responsibilities and personnel with information security responsibilities. In a small shop those are often the same person, and the question that separates a real answer from a rehearsed one is simple: where is the encryption key, and who can use it?

Encrypted backups whose key sits in the backup console on the same server that holds the CUI protect confidentiality against a stolen drive and very little else. Anyone who reaches the console reaches the key. A key held by the cloud provider moves the trust question onto that provider's validation and its own access controls. A key held offline, by named people, with a written procedure for retrieving it, is the arrangement an interviewer can follow from start to finish. None of these is forbidden. The security plan should say which one the program chose, and the person in the chair should give the same answer the plan does.

A backup nobody has restored is a claim about encryption. A restore is the evidence.

The test is a restore

The test list names the organizational processes for conducting backups and the mechanisms implementing them. An assessor may or may not exercise them. A program should, because a restore is the only event that proves several things at once.

Pull the offsite or cloud copy, not the local one, onto a clean machine. Before decrypting, try to open the raw backup file and confirm it is unreadable. Then retrieve the key through the written procedure, restore a sample of CUI, and confirm it arrived intact. Record the date, the source location, who held the key, how long retrieval took, and what failed. That one ticket shows the copy was encrypted where it sat, that the key lives where the plan says, that the people interviewed can do what they described, and that the backup works. The last fact is not something 3.8.9 asks about. It is the one the business will care about first if ransomware ever reaches the file share.

Immutable copies deserve the same candor. Object-lock storage and write-once retention are strong ransomware defenses, and nothing in 3.8.9 requires them. They are also storage locations like any other, encrypted or not, and a compliance-mode retention lock is built so that nobody can shorten it. CUI written there stays until the clock runs out, which matters the day a contract ends and the data must be destroyed under media sanitization rules. Set the retention period with the contract's disposition terms in hand, not the vendor's default.

None of this is a reason to panic about the point itself. Requirement 3.8.9 is worth 1 point and is not among the six 1-point requirements 32 CFR 170.21(a)(2)(iii) bars, so it can go on a Level 2 POA&M with one 180-day window to close, as the POA&M rules issue laid out. Even 3.13.11 carries the regulation's single exception for encryption that is present but unvalidated. A shop that finds its backup gap has room to fix it.

What it should not do is find the gap during the assessment. The question "where do the backups go?" sounds like it concerns one point. Its answer settles whether the cloud provider was vetted, whether the cryptography is validated, whether the Friday drive is transport, and whether the security plan describes the system that exists. The cheapest way to have that answer ready is to schedule one restore this quarter from the copy furthest away, and keep the ticket. If the restore turns up a destination nobody can explain, MacTech's enclave architecture notes show where a backup target sits when it is designed in rather than discovered, and a readiness check will tell you what else the table missed. ◆